PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Authentification multifacteur (MFA)

03-1280 CNIL - Recommandation relative à l'authentification multifacteur — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La MFA combine au moins deux catégories de facteurs distinctes comme la connaissance et la possession.
2. L'usage de la biométrie impose le consentement de la personne et la mise en place d'une alternative.
3. En 2026, 45 % des Français ont été informés d'une fuite de leurs données personnelles.

Notions fondamentales de la recommandation

Notion	À retenir
Objet de la recommandation	Conformité **RGPD** et **protection de la vie privée dès la conception** ; couvre l'**authentification au sens strict** (pas la gestion du cycle de vie des identités).
Définition MFA	MFA : au moins **2 catégories** (connaissance, possession, inhérence) ; ex. **carte + code PIN**. Mot de passe + code par **courriel** = **vérification en deux étapes (2SV)**, pas une MFA (pas d'objet physique unique). **IP/localisation** ne sont pas des facteurs.
MFA vs Robustesse	Une authentification peut être **cryptographiquement robuste** sans être MFA (ex: **clé d'accès logicielle**), ou **MFA** sans être robuste (ex: **mot de passe + OTP par SMS**).

Recommandations MFA

Notion	À retenir
Évaluer l'opportunité	Adapter aux risques via une **analyse de risque** (impact personnes). Recommandée pour **données sensibles (art. 9 RGPD)**, administration, accès extérieur et messagerie. Optionnelle pour **faible risque**.
Base légale et biométrie	Suit la **base légale du traitement principal** ou **art. 6** (intérêt légitime). Biométrie : nécessite **consentement libre** ou texte obligatoire ; **alternative obligatoire** si imposée.
Choisir et minimiser	Privilégier **connaissance** et **possession**. Stockage des **gabarits biométriques** : localement sur l'appareil. Qualifier **responsable de traitement/sous-traitant** et minimiser les données.
Conserver et sécuriser	Données d'authentification : durée de vie du compte (**OTP** : pas de conservation après usage). Journaux : **6 à 12 mois**, sans biométrie ni secret (uniquement **succès/échec**).

Synthèse Cybermois 2026

Notion	À retenir
Le baromètre 2026	Fuites de données : **45 %** des Français informés (contre **30 %** en 2025). Principal risque ensuite : un **hameçonnage personnalisé** nourri des données volées. Hameçonnage (**53 %**) en tête des malveillances.
Support CNIL / Cybermalveillance.gouv.fr	Dépliant `Violation de données personnelles, que faire en 3 étapes clés` disponible dès le **1er octobre 2026**.
Les bons réflexes	Changer les mots de passe, activer la **double authentification**, contacter l'organisme et prévenir la banque si l'**IBAN** a fuité.
La prévention	Communiquer le **minimum d'informations**, utiliser des mots de passe complexes et l'**authentification multifacteur**.
La campagne 2026	Campagne `Se cyber protéger, ce n'est pas si bête` (**7 animaux**) et **CyberTour** (départ Biarritz le **1er octobre**).

Données clés du baromètre 2026

2000
personnes interrogées (18 à 75 ans)
par Ipsos, du 13 au 18 mai 2026

53 %
Français ayant changé leurs mots de passe après une fuite

59 %
Français plus vigilants face aux messages/appels inconnus

13 %
Français ayant contacté l'organisme après une fuite

62 %
Connaissance du terme violation de données
contre 48 % en 2024

15 %
Faux conseiller bancaire
2e malveillance

10 %
Commande jamais livrée sur site frauduleux
3e malveillance

Pièges et confusions

- ⚠ Confondre la MFA avec la vérification en deux étapes (2SV) qui enchaîne deux facteurs de même catégorie.
- ⚠ Croire qu'un code reçu par courriel constitue un facteur de possession.
- ⚠ Penser qu'une authentification cryptographiquement robuste est forcément une MFA.
- ⚠ Considérer que l'adresse IP ou la localisation sont des facteurs d'authentification.
- ⚠ Oublier qu'une MFA peut être utilisée sans être nécessairement robuste (ex: mot de passe + OTP par SMS).

Sigles et définitions

MFA	Authentification s'appuyant sur plusieurs facteurs appartenant à au moins deux catégories distinctes
2FA	Authentification avec exactement deux facteurs
Facteur de connaissance	Ce que la personne sait : mot de passe, phrase de passe ou code PIN
Facteur de possession	Ce que la personne a : jeton matériel ou jeton logiciel lié à un appareil enrôlé
Facteur d'inhérence	Ce que la personne est ou fait : caractéristique morphologique, comportementale ou biologique
OTP	Code à usage unique
DPO	Délégué à la protection des données qui veille à la conformité au RGPD

Auto-test

1. Quelles sont les trois catégories de facteurs d'authentification ?
2. La vérification en deux étapes (2SV) est-elle une MFA ?
3. Quelle est la durée de conservation recommandée pour les journaux ?
4. Quel est le principal risque après une fuite de données ?
5. Où doivent être stockés les gabarits biométriques ?

Réponses : **1.** Connaissance, possession et inhérence · **2.** Non · **3.** 6 à 12 mois · **4.** Le hameçonnage personnalisé · **5.** Localement sur l'appareil

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.